

# RiskOnto: An Ontology-Driven Framework for Threat Modeling, Risk Reasoning and Cyber Defense Knowledge Integration

<sup>1st</sup> Michael Adekunle Adelere  
Faculty of Computer Science  
University of New Brunswick  
Fredericton, Canada  
michael.adelere@unb.ca

<sup>2nd</sup> Yasser Morgan  
Schaefer School of Engineering and Science  
Stevens Institute of Technology  
NJ, USA

<sup>3rd</sup> Luigi Benedicenti  
Faculty of Computer Science  
University of New Brunswick  
Fredericton, Canada

**Abstract**—We present RiskOnto, an OWL 2 DL ontology-driven framework for automated cybersecurity risk assessment that integrates MITRE ATT&CK, MITRE D3FEND, MITRE CWE, the NIST Cybersecurity Framework (CSF) 2.0, and NIST SP 800-53 Revision 5. RiskOnto comprises 103,906 RDF triples organized around 121 VulnerabilityProfile archetypes that represent recurring vulnerability patterns and serve as semantic anchors for cross-framework reasoning. Offline materialization of 13 global SWRL rule specifications, organized into three functional sublayers, produced 19,671 reusable semantic assertions (from the 8 inference/explanation rules, R1–R4/E1–E4) and 847 VP-level hasJustification links to typed XAI justification/explanation individuals (from the remaining 5, X1–X5). The core-reasoning sublayer infers NIST CSF impacts and propagates ATT&CK mitigation and MITRE D3FEND recommendations. The explainability sublayer generates rule-grounded assertions covering risk, candidate NIST CSF 2.0 framework-outcome associations, mitigations, and defenses, while the structured XAI sublayer links vulnerability profiles to typed justification and recommendation records that support transparent and auditable risk decisions. Risk is represented using an ordinal Impact  $\times$  Likelihood model informed by NIST SP 800-30 Rev. 1, assigning scores from 1 to 25 across five criticality tiers, from Very Low to Critical, represented by 352 RiskAssessment individuals. A System Under Test (SUT) integrates with the shared knowledge base through a standardized six-step pipeline using a single OWL import declaration and SUT-specific vulnerability-profile links, without modifying RiskOnto. We validate the framework using WebGoat 2025.4-SNAPSHOT, a deliberately insecure Spring Boot application. Four heterogeneous scanner tools generated 273 raw findings, of which 166 were within the current CWE-representable canonicalization scope and consolidated into 43 canonical security findings; 107 findings remained outside the current CWE-based canonicalization scope. All 43 canonical findings activated at least one VulnerabilityProfile, demonstrating complete workflow coverage of the normalized security findings, while *not* establishing semantic correctness of every association. The case study demonstrates RiskOnto’s ability to consolidate heterogeneous security evidence, perform reusable cross-framework semantic reasoning, identify framework outcomes potentially associated with vulnerabilities, represent risk, and generate traceable cybersecurity recommendations.

**Index Terms**—Cybersecurity, Ontology, Threat Modeling, Risk Reasoning, NIST CSF 2.0, MITRE D3FEND, CMM, OWL, SWRL, Risk Management, WebGoat, XAI.

TABLE I: List of Acronyms

| Acronym      | Definition                                           |
|--------------|------------------------------------------------------|
| ATT&CK       | Adversarial Tactics, Techniques and Common Knowledge |
| CMM          | Capability Maturity Model                            |
| CSF          | Cybersecurity Framework                              |
| CWE          | Common Weakness Enumeration                          |
| DL           | Description Logic                                    |
| GDPR         | General Data Protection Regulation                   |
| MITRE D3FEND | MITRE Defensive Knowledge Graph (D3FEND)             |
| NIST         | National Institute of Standards and Technology       |
| OWL          | Web Ontology Language                                |
| RDF          | Resource Description Framework                       |
| SP           | Special Publication                                  |
| SWRL         | Semantic Web Rule Language                           |
| SUT          | System Under Test                                    |
| VP           | VulnerabilityProfile                                 |
| XAI          | Explainable Artificial Intelligence                  |

## I. INTRODUCTION

Cybersecurity threats continue to evolve in frequency and sophistication, and effective risk management requires a comprehensive understanding of threats, vulnerabilities and appropriate defensive actions, yet traditional risk assessment methodologies struggle to capture the complex interdependencies within modern IT environments. A core issue is the absence of semantic integration across frameworks and tools: standards such as the NIST Cybersecurity Framework (CSF) [1], MITRE ATT&CK and MITRE D3FEND provide valuable taxonomies, but their practical application often lacks the semantic links needed for automated reasoning and comprehensive risk assessment. This is compounded by the rapid evolution of AI-powered systems, which introduce new vulnerabilities of their own [3], and by the difficulty traditional mechanisms have with causal reasoning: understanding root causes or predicting cascading effects. The lack of structured, traceable justification in automated systems further hinders analysts from understanding the rationale behind recommenda-

tions, reducing trust in complex, time-sensitive environments.

This research addresses these challenges with an ontology-driven approach to threat modeling and risk reasoning. By formalizing semantic relationships between cybersecurity concepts, RiskOnto enables rule-based reasoning, cross-framework interoperability and structured, machine-traceable justification, supporting a more proactive cyber defense posture with traceable recommendations for mitigation.

The **principal contributions** of this work are:

- 1) **Unified Cyber Knowledge Graph:** An OWL 2 DL ontology (103,906 RDF triples) that formally integrates MITRE ATT&CK, MITRE D3FEND, MITRE CWE, NIST CSF 2.0 and NIST SP 800-53 Rev 5 [8] into a single queryable knowledge graph with a common vocabulary.
- 2) **VulnerabilityProfile Architecture:** 121 canonical VulnerabilityProfile archetypes, each pre-linked to CWE identifiers, ATT&CK threat techniques, NIST CSF subcategories, recommended mitigations and MITRE D3FEND defensive techniques, enabling reasoning without SWRL re-execution for any new System Under Test whose findings map to the existing VP library.
- 3) **Four-Sublayer SWRL Reasoning Engine:** 14 formally-declared SWRL rules in four sublayers (threat/framework-outcome/mitigation inference; explanation-link annotation; structured justification output; SUT-side activation). Of the 13 global rules, R1–R4/E1–E4 materialize 19,671 reusable assertions once, offline, and X1–X5 generate 847 VP-level `hasJustification` links to typed XAI individuals; the 14th (SI-12) binds each SUT finding to its VP at population time.
- 4) **Structured Semantic Justification Output:** Per VulnerabilityProfile, typed justification records (`RiskJustification`, `MitigationJustification`, `ComplianceJustification` and `RecommendationStatement`) provide rule-traceable, machine-readable risk explanations without post-hoc approximation; human-comprehensibility is not evaluated in this study (§VIII-H).
- 5) **Scanner-Agnostic SUT Integration Pipeline:** A six-step workflow enabling a System Under Test (application, API, container, infrastructure) to inherit the pre-materialized global reasoning chain and trigger SUT-side profile activation (SI-12) via a single OWL import declaration, provided its findings map to RiskOnto’s existing VulnerabilityProfile archetypes; validated with four heterogeneous scanners on WebGoat 2025.4-SNAPSHOT.

The remainder of this paper proceeds as follows: Section II surveys related work and the research gap; Section III gives NIST CSF 2.0 background; Section IV presents the methodology; Section V the architecture; Section VI CMM alignment; Section VII the ontology quality evaluation; Section VIII the WebGoat case study; and Section IX concludes.

## II. RELATED WORK

Ontology-driven cybersecurity risk management has grown substantially, motivated by the need to automate threat intelligence analysis, compliance mapping and risk scoring across heterogeneous environments. This section surveys the literature in four areas, then identifies the resulting research gaps.

### A. Ontology-Based Cyber Risk Assessment

Early OWL-based knowledge graphs formalized relationships among assets, threats, vulnerabilities and controls for structured risk assessment: Park and Lee [17] encoded causal dependencies between security events to support risk decisions; Al Hammouri and Al Bataineh [7] proposed a unified cyber threat intelligence ontology integrating multiple threat taxonomies; Kaloroumakis and Smith’s *OnToRisk* [24] mapped vulnerability attributes to risk classes via CVE/CWE identifiers; the NIST Unified Ontology project [20] outlined design principles for a cross-domain, NIST-aligned cybersecurity knowledge graph. These ontologies advance structured risk *identification*, but the semantic link from a technical finding through attack techniques and defensive countermeasures to an organizational security function is not formalized as an executable reasoning chain.

### B. Multi-Source Cybersecurity Knowledge Graph Approaches

A closely related line of work builds multi-source cybersecurity knowledge graphs for linked-data querying: Syed et al.’s Unified Cybersecurity Ontology (UCO) [29] integrates CVE, NVD, CPE, CAPEC, ATT&CK and CWE into a shared OWL vocabulary for cross-source queries; SEPSES [30] extends this into a continuously maintained linked-data ecosystem with automated ingestion, advancing reproducibility at scale. These systems demonstrate feasible large-scale, multi-source OWL graphs, but focus on *knowledge organization and SPARQL retrieval* rather than *automated reasoning*: neither incorporates SWRL-driven framework-outcome association, integrates MITRE D3FEND (released 2021, after UCO), implements a scanner-agnostic SUT pipeline, or generates per-finding XAI justification records. Table II omits them as column categories since their orientation is complementary, not competitive: SEPSES and UCO are potential upstream data providers; RiskOnto addresses the reasoning, explainability and SUT-integration layer above them.

### C. Threat Modeling Ontologies

A parallel line of research applies ontologies to automate threat modeling. Vålja et al. [14] showed threat modeling for complex IT architectures can be substantially automated by combining ontological system representations with ATT&CK-based threat libraries, reducing manual effort. Kougioumtzidou et al. [2] presented a framework for automated generation and updating of cybersecurity taxonomies enabling continuous alignment with evolving threats, demonstrated on operational learning factories [19]. These systems focus primarily on threat *identification* rather than the defensive response mapping threats to mitigations, associating findings with candidate

framework outcomes, or generating traceable justifications and neither integrates the MITRE D3FEND knowledge base, which encodes defensive techniques at the specificity needed for actionable recommendations.

#### D. Framework-Integrated and Domain-Specific Ontologies

A third category integrates multiple standards or targets specific deployment domains: Preuveneers and Joosen [13] aligned AI-enabled-system cybersecurity properties with NIST guidelines; Bughio et al. [15] developed a cybersecurity ontology for Internet of Medical Things environments; Agarwal et al. [4] addressed GDPR-inspired privacy/security semantics for IoT; Madhavan et al. [3] quantified gaps in AI security standards, illustrating the difficulty of aligning heterogeneous frameworks without a shared semantic layer.

The AI Risk Ontology (AIRO) [25] developed in alignment with the proposed EU AI Act and ISO 31000:2018 represents AI-specific risks and risk sources within a formal OWL framework advancing regulatory compliance modeling for AI products by formalizing risk categories, likelihood and severity in a machine-interpretable structure. AIRO and RiskOnto address complementary problem domains: AIRO targets governance and regulatory risk representation for AI systems, while RiskOnto provides executable threat reasoning, ATT&CK and MITRE D3FEND integration, and SWRL-driven association of vulnerability findings with candidate NIST CSF 2.0 outcomes, applicable to Systems Under Test whose scanner evidence maps to RiskOnto's existing VulnerabilityProfile archetypes.

These contributions demonstrate that ontology-driven frameworks can be tailored to domain constraints. However, each is scoped to a specific system category or standard pair; none provides a scanner-agnostic integration pipeline through which heterogeneous vulnerability evidence from a System Under Test activates a full cross-framework reasoning chain without modifying the shared knowledge graph.

#### E. Risk Quantification and Non-Semantic Approaches

Non-ontological risk quantification models provide important foundational approaches. NIST SP 800-30 Rev 1 [10] defines a procedural risk assessment methodology quantifying likelihood and impact and expressing risk as their product which RiskOnto formalizes in OWL with 352 RiskAssessment individuals. The FAIR model [11] provides an actuarial quantification framework for information risk. The ENISA Interoperable EU Risk Management Framework [12] and ISO 31000:2018 [22] establish governance-level principles. These frameworks provide well-validated risk reasoning models but are procedural or mathematical in character: they lack OWL formalization, SWRL-driven inference and the ability to automatically link a vulnerability finding to a structured justification referencing specific governance subcategories and defensive technique libraries.

#### F. Research Gap

The survey above reveals six persistent limitations in the existing literature:

**G1. Narrow Scope.:** Most ontologies address vulnerability modeling, threat modeling, *or* compliance modeling in isolation [14], [15], [17], [24] rather than providing a single framework that spans all three.

**G2. Fragmented Knowledge Source Integration.:** Prior systems integrate one or two knowledge bases (e.g., CWE with ATT&CK, or NIST CSF alone) but not CWE, ATT&CK, D3FEND, NIST CSF 2.0 and SP 800-53 concurrently within a single executable knowledge graph [7], [20], [24].

**G3. Missing Defensive Reasoning.:** Most threat modeling systems identify attack techniques but do not automatically map findings to MITRE D3FEND defensive technique recommendations via SWRL rules [2], [14].

**G4. Lack of Formalized Explainability.:** Existing systems produce risk classifications or control recommendations without traceable, per-finding justification records that can be inspected by human analysts [7], [13].

**G5. Weak Automated Framework-Outcome Association.:** Most frameworks align conceptually with governance standards but do not automatically identify which NIST CSF 2.0 subcategories and SP 800-53 controls are potentially implicated by a given vulnerability finding [4], [15].

**G6. No End-to-End Semantic Traceability.:** To our knowledge, no existing published system provides a continuous, SPARQL-queryable semantic chain from a canonical vulnerability archetype to an organizational security function— $VP \rightarrow CWE \rightarrow ATT\&CK \rightarrow Mitigation \rightarrow D3FEND \rightarrow NIST\ CSF\ Subcategory \rightarrow CSF\ Function$  within a single shared ontology [14], [17], [24].

Table II contrasts RiskOnto against representative prior approaches across these gap dimensions.

Table II shows that while each prior approach addresses one or more dimensions of the cybersecurity risk problem, none provides the full capability profile in combination. The contribution of RiskOnto is not ontology integration alone, but the executable *combination* of: (a) a five-source knowledge graph enabling cross-framework SPARQL queries; (b) SWRL-automated reasoning replacing manual annotation for every new SUT; (c) a seven-step end-to-end traceability chain from scanner evidence to governance function; (d) formalized XAI output enabling transparent, auditable risk decisions; and (e) scanner-agnostic SUT deployment requiring no modification to the shared RiskOnto. This combination closes the full six-gap profile (G1–G6, §II-F) that no single prior approach resolves.

#### G. Contributions of RiskOnto

In direct response to gaps G1–G6, RiskOnto makes six measurable contributions not found in combination in existing work:

**N1 — Unified Five-Source Cyber Knowledge Graph (G2).** A single OWL 2 DL graph (103,906 triples, 123 classes) formally integrates CWE (264), MITRE ATT&CK (995), MITRE D3FEND (383), NIST CSF 2.0 (106) and NIST SP 800-53 Rev 5 (119), enabling cross-framework SPARQL queries not possible when sources are managed separately.

TABLE II: Comparative Analysis: RiskOnto and Representative Prior Approaches

| Feature                       | OnToRisk [24] | Threat Modeling [14] | Domain Ontol. [13], [15] | Risk Frameworks [10], [11] | RiskOnto (This Work) |
|-------------------------------|---------------|----------------------|--------------------------|----------------------------|----------------------|
| OWL-based ontology            | ✓             | ✓                    | ✓                        | ×                          | ✓                    |
| Cyber risk assessment         | ✓             | Partial              | Partial                  | ✓                          | ✓                    |
| ATT&CK integration            | Partial       | ✓                    | ×                        | ×                          | ✓                    |
| CWE integration               | ✓             | Partial              | ×                        | ×                          | ✓                    |
| D3FEND integration            | ×             | ×                    | ×                        | ×                          | ✓                    |
| NIST CSF 2.0 integration      | ×             | ×                    | Partial                  | Partial                    | ✓                    |
| SP 800-53 integration         | ×             | ×                    | ×                        | Partial                    | ✓                    |
| Framework-outcome association | ×             | ×                    | Partial                  | ×                          | ✓                    |
| SWRL automated reasoning      | ×             | ×                    | ×                        | ×                          | ✓                    |
| Formalized XAI output         | ×             | ×                    | ×                        | ×                          | ✓                    |
| End-to-end traceability chain | ×             | Partial              | ×                        | ×                          | ✓                    |
| Scanner-agnostic SUT pipeline | ×             | ×                    | ×                        | ×                          | ✓                    |
| Quantitative risk scoring     | Partial       | ×                    | Partial                  | ✓                          | ✓                    |
| Empirical SUT validation      | ×             | Partial              | Partial                  | ×                          | ✓                    |

✓ = explicitly demonstrated in the cited publication(s); Partial = limited/conditional support per the source; × = not reported in the cited publication(s), an evidence gap in the published description, not a verified claim of structural incapability. Columns represent categories rather than individual papers. Domain Ontol.: Preuveneers & Joosen (2024) [13]; Bughio et al. (2024) [15]. Risk Frameworks: NIST SP 800-30 [10]; FAIR [11].

**N2 — Seven-Layer Semantic Architecture (G1).** A layered pipeline from raw scanner evidence through OWL semantic materialization to structured intelligence output. RiskOnto (Layer 5) and SWRL Reasoning Engine (Layer 6) are shared across all SUTs without modification, addressing the domain-scoping limitation of existing frameworks.

**N3 — Seven-Step End-to-End Traceability Chain (G6).** For any matched VulnerabilityProfile: VP → CWE → ATT&CK Technique → ATT&CK Mitigation → D3FEND Technique → NIST CSF Subcategory → CSF Function fully derivable via SPARQL with no manual annotation. In the WebGoat case study, SQL Injection (CWE-89) traces to 4 ATT&CK techniques, 22 mitigations, 134 D3FEND techniques and 45 NIST CSF subcategories automatically.

**N4 — Automated Framework-Outcome Association (G5).** SWRL rules R1 and R2 materialized 5,318 affectsSubcategory and 605 affectsFunction assertions automatically identifying which NIST CSF 2.0 subcategories and functions are potentially implicated by each vulnerability, without manual cross-reference. RiskOnto identifies framework outcomes associated with a vulnerability; it does not determine legal or organizational compliance status, which requires evidence of implemented controls and a normative conformance assessment outside the scope of this study.

**N5 — Structured Semantic Justification Layer (G4).** Per-VulnerabilityProfile OWL individuals of eight typed justification-record classes (RiskJustification, MitigationJustification, ComplianceJustification, ReasoningTrace, EvidenceStatement, RootCauseExplanation, ImpactExplanation, RecommendationStatement) make the reasoning chain inspectable, auditable and reproducible.

**N6 — Scanner-Agnostic SUT Integration (G1, G3).** A six-step integration pipeline accepting evidence from SAST, DAST, SCA, or infrastructure scanners via a Unified Vulnerability Schema, validated across four heterogeneous tools on WebGoat 2025.4-SNAPSHOT: of 273 raw findings, 166 CWE-eligible findings were canonicalized to 43 (§VIII).

### III. BACKGROUND

#### A. NIST Cybersecurity Framework 2.0

The NIST Cybersecurity Framework (CSF) 2.0 [1] released February 26, 2024 (NIST CSWP 29) is a voluntary and flexible standard for managing cybersecurity risk across organizations of all sizes and sectors. CSF 2.0 organizes cybersecurity outcomes into a three-tier hierarchy: six **Functions**, 22 **Categories** and 106 **Subcategories**. Table III summarizes the six Functions; for complete documentation see [1].

TABLE III: NIST CSF 2.0: The Six Core Functions

| Function (Code) | Focus Area                                                   |
|-----------------|--------------------------------------------------------------|
| GOVERN (GV)     | Cybersecurity risk management strategy, policy and oversight |
| IDENTIFY (ID)   | Organizational assets, risks and threat exposure             |
| PROTECT (PR)    | Safeguards: access control, training, data security          |
| DETECT (DE)     | Discovery and analysis of cybersecurity events               |
| RESPOND (RS)    | Containment and management of detected incidents             |
| RECOVER (RC)    | Restoration of capabilities after an incident                |

### IV. METHODOLOGY

RiskOnto was developed following an iterative ontology engineering lifecycle adapted from the NeOn methodology [26]. The process comprises five phases described in this section: (1) requirements analysis and competency questions; (2) knowledge source integration; (3) semantic mapping framework construction; (4) SWRL rule design; and (5) validation.

#### A. Ontology Engineering Approach

The ontology engineering process was driven by a set of **competency questions (CQs)** that the final knowledge graph must answer without human intervention:

- **CQ1:** Given a vulnerability finding, which ATT&CK techniques exploit it and which NIST CSF 2.0 subcategories does it affect?

- *CQ2*: For a given vulnerability, what mitigations are recommended and which MITRE D3FEND techniques implement them?
- *CQ3*: What is the composite risk score (Impact  $\times$  Likelihood) for a given asset-vulnerability pair and in which criticality tier does it fall?
- *CQ4*: Can every output assertion be traced to its source scanner finding, its SWRL rule and its XAI justification record?

The ontology was constructed in four sequential phases: (i) TBox design (class hierarchy, object and datatype properties, OWL axioms); (ii) ABox population (individuals from five knowledge sources); (iii) SWRL rule addition and execution; and (iv) reasoning certification (OWL 2 DL consistency check, OOPS! pitfall scan [21], OntoMetrics structural evaluation). The modular design separates the RiskOnto (riskonto: namespace) from a Mapping graph (mappings: namespace) and SUT-specific ontologies, preventing knowledge source conflicts and enabling independent versioning.

### B. Knowledge Source Integration

Five knowledge sources were ingested and aligned to the riskonto: namespace. Table IV summarizes the source, version, individual count and integration mechanism for each.

TABLE IV: RiskOnto: Knowledge Source Integration Summary

| Source         | Version   | Count | Integration                                                                                                            |
|----------------|-----------|-------|------------------------------------------------------------------------------------------------------------------------|
| MITRE ATT&CK   | v14       | 995   | XML STIX export; each technique $\rightarrow$ AttackTechnique individual; exploitableByTechnique links VP to technique |
| MITRE D3FEND   | v1.0      | 383   | SPARQL pull from d3fend.mitre.org; techniques in d3fend: namespace; implementedBy links mitigation to D3FEND           |
| MITRE CWE      | v4.20     | 264   | CWE XML; each weakness $\rightarrow$ CWE individual; mappedToCWE links VP to CWE                                       |
| NIST CSF 2.0   | Feb. 2024 | 106   | NIST CSWP 29 spreadsheet; subcategories $\rightarrow$ NISTSubcategory; function membership via belongsToFunction       |
| NIST SP 800-53 | Rev 5     | 119   | OSCAL JSON feed; controls $\rightarrow$ Control; hasControl links subcategory to control                               |

A total of **2,824 Mapping individuals** bridge ATT&CK techniques to ATT&CK mitigations, each carrying a confidenceScore of 0.6. This value is a *provenance marker* rather than a calibrated probability of correctness: it indicates that the mapping was derived programmatically from the MITRE ATT&CK STIX v14 export through semi-automatic extraction and was not individually verified by a human expert beyond spot-checking. Accordingly, the 0.6 value should not be interpreted as evidence that the mapping is 60% correct; semantic mapping accuracy remains subject to future expert-grounded validation. Mappings with Status = ``Incomplete`` are excluded from active reasoning paths and flagged for manual review in future ontology versions.

The generated XAI justification records also use a confidenceScore derived from a deterministic evidence-density heuristic based on supporting links relative to a fixed per-type threshold. This score is likewise not a calibrated probability. The justification records are therefore presented as structured semantic evidence and traceability mechanisms rather than as evidence of validated human comprehensibility or analyst usefulness, which remain subjects for future evaluation.

### C. Semantic Mapping Framework

The distinguishing architectural feature of RiskOnto is an **eight-step semantic mapping chain** that connects a VulnerabilityProfile to a NIST CSF Function (ontology class Function) through a sequence of asserted and inferred relationships:

TABLE V: RiskOnto Eight-Step Semantic Mapping Chain

| Step | Source          | Property                     | Target          |
|------|-----------------|------------------------------|-----------------|
| 1    | VP              | mappedToCWE                  | CWE             |
| 2    | CWE             | recommended-Mitigation       | Mitigation      |
| 3    | VP              | exploitable-ByTechnique      | AttackTechnique |
| 4    | AttackTechnique | mitigatedBy                  | Mitigation      |
| 5    | Mitigation      | implementedBy                | D3FENDTechnique |
| 6    | Mitigation      | supports-Subcategory         | NISTSubcategory |
| 7    | VP              | affectsSubcategory (SWRL R1) | NISTSubcategory |
| 8    | NISTSubcategory | belongsToFunction            | Function        |

Steps 1–6 and 8 are *asserted* ABox facts populated during knowledge source integration. Step 7 is *inferred* by SWRL rule R1 from steps 3–4 and 6 (Section IV-D), materialized offline once against the global ontology (§IV-E); R2 subsequently lifts step 7’s output to affectsFunction(VP, Function) (605 assertions) via step 8, not separately tabulated since it restates the VP–Function endpoint step 8 already reaches. A SUT does not re-execute these rules; it inherits the pre-materialized results through OWL property traversal when its findings activate a VP. This split between asserted and inferred links is what makes RiskOnto’s approach distinct from static mapping tables: each new SUT finding, once bound to a VP via activatesProfile (SI-12), reaches the entire pre-materialized chain without manual annotation or re-reasoning.

For SQL Injection (CWE-89), the complete chain produces: 4 ATT&CK techniques, 45 NIST CSF subcategories across 5 of 6 CSF Functions, 22 MITRE ATT&CK mitigations and 134 MITRE D3FEND defensive techniques—all reachable from the finding via its activatesProfile link to VulnProfile\_SQL\_Injection (Fig. 7).

*a) Formal Mapping Relations.:* Because a source individual may map to multiple targets (e.g., 370 exploitableByTechnique triples across 121 VPs), the mapping constructs underlying the chain above are finite binary relations, not total single-valued functions. The relations feeding the core VP-to-Function composition are:

|                                   |                                |                                   |
|-----------------------------------|--------------------------------|-----------------------------------|
| $R_{VP,ATT} : VP$                 | $\rightarrow$ AttackTechnique  | exploitableByTechnique (asserted) |
| $R_{ATT,MIT} : AttackTechnique$   | $\rightarrow$ Mitigation       | mitigatedBy (asserted)            |
| $R_{MIT,CSF} : Mitigation$        | $\rightarrow$ NIST-Subcategory | supportsSubcategory (asserted)    |
| $R_{CSF,FUNC} : NIST-Subcategory$ | $\rightarrow$ Function         | belongsToFunction (asserted)      |

SWRL rule R1 materializes  $R_{VP,CSF} = R_{MIT,CSF} \circ R_{ATT,MIT} \circ R_{VP,ATT}$  as the asserted relation `affectsSubcategory` (5,318 triples); R2 materializes  $R_{VP,FUNC} = R_{CSF,FUNC} \circ R_{VP,CSF}$  as `affectsFunction` (605 triples). The separate Mitigation-recommendation path (Table V, steps 1–2:  $R_{VP,CWE} \subseteq VP \times CWE$ ,  $R_{CWE,MIT} \subseteq CWE \times Mitigation$ ) feeds R3’s output `recommendedFor`, not this composition.

#### D. SWRL Rule Design

The RiskOnto reasoning engine comprises **14 formally-declared SWRL rules** (`swrl:Imp` individuals, confirmed by direct query), organized in four sublayers separating structural inference, explanation generation, XAI materialization and SUT-side activation. **13 are global** (SI-7, SI-9, SI-11), materialized once offline into reusable cross-SUT assertions; the 14th (SI-12) activates per SUT population. None of the 14 is executed by a certified SWRL/DL reasoner; all are materialized by an equivalent Python/`rdflib` graph-traversal implementation (§IV-E).

**Sublayer SI-7 — Core Reasoning (Rules R1–R4):** Infers new structural facts from asserted ABox data. R1 traverses the technique–mitigation–subcategory chain to materialize `affectsSubcategory` for each VP (5,318 assertions). R2 lifts subcategory assertions to CSF Function level (605 assertions). R3 and R4 propagate mitigation and D3FEND recommendations (505 and 3,326 assertions, respectively).

**Sublayer SI-9 — Explanation-Link Annotations (Rules E1–E4):** Annotates inferred facts with semantically-named, SPARQL-retrievable object-property links (not literal natural-language text): `explainsMitigation` (2,437), `explainsDefense` (2,015), `explainsComplianceGap` (5,318) and `explainsRisk` (147).

**Sublayer SI-11 — Structured Semantic Justification Output (Rules X1–X5):** Populates seven typed justification-record classes once per VP (121 individuals each): `RiskJustification` (with `derivedFromRule`, `hasRiskLevel`, `confidenceScore`), `MitigationJustification`, `RecommendationStatement`, `RootCauseExplanation`, `EvidenceStatement` and `ImpactExplanation`, each connected to its VP via `hasJustification` (847 assertions across 121 VPs,  $\approx 7$  per VP). `DefenseJustification` is an eighth, smaller mitigation-scoped type (42 individuals, one per mitigation rather than one per VP). Separately, the SI-9 explanation sublayer (below) additionally builds one `ReasoningTrace`

individual per VP (121 total), synthesizing the VP’s CWE/ATT&CK/D3FEND/NIST CSF chain into a labeled, human-readable trace linked via `hasReasoningTrace` and `hasExplanation`; unlike the seven SI-11 types above, it is not tied to a named SWRL rule specification. **Sublayer SI-12 — SUT Profile Activation (Rule A1):** A single rule, executed during SUT ontology population (not during global ontology construction), binds each canonical SUT finding to one or more global `VulnerabilityProfile` archetypes by CWE match, asserting `activatesProfile`. In the WebGoat case study (§VIII), this produced 76 `activatesProfile` assertions across the 43 canonical findings.

Table VI lists the 13 global rules with their URIs, layers, and verified output counts; the 14th rule (SI-12) is listed separately since its output is SUT-specific rather than a fixed global count.

TABLE VI: RiskOnto SWRL Rule Inventory

| ID                                                         | Layer | Output Property / Type                                   | Count         |
|------------------------------------------------------------|-------|----------------------------------------------------------|---------------|
| R1                                                         | SI-7  | <code>affectsSubcategory</code>                          | 5,318         |
| R2                                                         | SI-7  | <code>affectsFunction</code>                             | 605           |
| R3                                                         | SI-7  | <code>recommendedFor</code>                              | 505           |
| R4                                                         | SI-7  | <code>recommendedD3FEND</code>                           | 3,326         |
| E1                                                         | SI-9  | <code>explainsMitigation</code>                          | 2,437         |
| E2                                                         | SI-9  | <code>explainsDefense</code>                             | 2,015         |
| E3                                                         | SI-9  | <code>explainsComplianceGap</code>                       | 5,318         |
| E4                                                         | SI-9  | <code>explainsRisk</code>                                | 147           |
| X1                                                         | SI-11 | <code>RiskJustification</code> (per VP)                  | 121           |
| X2                                                         | SI-11 | <code>MitigationJustification</code>                     | 121           |
| X3                                                         | SI-11 | <code>DefenseJustification</code> (mitigation-scoped)    | 42            |
| X4                                                         | SI-11 | <code>ComplianceJustification</code>                     | 121           |
| X5                                                         | SI-11 | <code>RecommendationStatement</code>                     | 121           |
| <b>Total global-materialized assertions (R1–R4, E1–E4)</b> |       |                                                          | <b>19,671</b> |
| A1                                                         | SI-12 | <code>activatesProfile</code> (per SUT; WebGoat example) | 76            |

An example SWRL rule body (R1 notation):

```
VP(?vp) ^ exploitableByTechnique(?vp,?t) ^
AttackTechnique(?t) ^ mitigatedBy(?t,?m) ^
Mitigation(?m) ^ supportsSubcategory(?m,?sc) ^
NISTSubcategory(?sc)
=> affectsSubcategory(?vp,?sc)
```

The 13 global rules (R1–R4, E1–E4, X1–X5) were executed *once*, offline, against the fully populated global ontology, with results serialized back as explicit RDF assertions; the SI-12 activation rule executes separately, per-SUT, likewise writing its results (`activatesProfile`) rather than computing them live. The full offline/runtime execution model, including the separate role of HerMiT, is detailed in §IV-E below. Complete formal specifications for all 13 global SWRL rules are provided in Appendix A.

#### E. Reasoning Execution Model

The 19,671 materialized assertions represent a **pre-materialized** reasoning output: all 13 SWRL rules are formally declared in the ontology as `swrl:Imp` individuals (body/head atoms, for reasoner interoperability) and were materialized, at ontology construction time, by a Python/`rdflib` forward-chaining implementation executing each rule’s antecedent–consequent pattern via graph traversal; the resulting inferred triples were serialized back into the

ontology file. Separately, OWL 2 DL **consistency checking** (not SWRL materialization) of the RiskOnto ontology was performed with the **HermiT 1.4.3.456** reasoner, started through Protégé; HermiT reported **no ontology inconsistencies**. The two mechanisms serve different purposes and are not interchangeable; HermiT verifies that the asserted and materialized ABox together admit no unsatisfiable classes, while the Python/`rdflib` pipeline is what actually generated the 19,671 assertions and the 847 VP-level `hasJustification` links reported throughout this paper. This pre-materialization strategy serves two purposes: (1) it eliminates per-SUT reasoning latency since inferred VP-level assertions are already present as explicit RDF triples when any SUT loads the ontology file; (2) it enables the full reasoning output to be inspected, version controlled and verified via SPARQL without requiring a live reasoner on the deployment system.

For a new System Under Test, reasoning proceeds in two phases. In the *global phase*, all 19,671 pre-materialized assertions are loaded as asserted ABox facts through the single `owl:imports` declaration. In the *SUT phase*, new `hasVulnerability` assertions linking a SUT asset to an existing RiskOnto `VulnerabilityProfile` inherit all pre-materialized VP properties through OWL property traversal, no SWRL re-execution is required for matched VPs. Extending RiskOnto to a `VulnerabilityProfile` not yet present in the ontology (i.e., a new vulnerability archetype) would require re-running the same Python/`rdflib` materialization procedure against the extended graph before SUT loading; this extension path has not been exercised in the present study and is identified as future work, not a demonstrated capability. This architecture ensures deterministic, reproducible reasoning for all 121 existing VP archetypes, which require no such re-execution.

#### F. Validation Approach

The framework was validated along three dimensions:

- 1) **Structural validation:** OWL 2 DL consistency checking with HermiT 1.4.3.456 via Protégé (no inconsistencies reported, §IV-E); OOPS! pitfall scan (all non-license pitfalls cleared); OntoMetrics structural metrics (reported in Section VII).
- 2) **Functional validation:** SPARQL query verification of all 13 rule output properties against expected counts (Table VI); confirmed via `rdflib` 7.6.0 direct graph traversal.
- 3) **Case study validation:** End-to-end integration with WebGoat 2025.4-SNAPSHOT using four heterogeneous scanners, presented in Section VIII.

#### V. ARCHITECTURE AND COMPONENTS OF RISKONTO

RiskOnto is a modular, OWL 2 DL ontology-driven framework comprising **103,906 RDF triples**, **123 OWL classes**, **70 object properties** and **24 datatype properties**. Its seven-layer architecture (Fig. 1) spans input source ingestion, scanner normalization, semantic materialization, RiskOnto storage, SWRL reasoning, structured justification output and human-readable

reporting. Table VII summarizes the verified capabilities of RiskOnto.

TABLE VII: RiskOnto: Verified Framework Capabilities

| Capability                            | Count   |
|---------------------------------------|---------|
| Total RDF triples                     | 103,906 |
| OWL 2 DL Classes                      | 123     |
| Object properties                     | 70      |
| Datatype properties                   | 24      |
| VulnerabilityProfile archetypes       | 121     |
| ATT&CK techniques (referenced)        | 61      |
| NIST CSF 2.0 subcategories (affected) | 45      |
| MITRE D3FEND techniques (reachable)   | 136     |
| ATT&CK mitigations (linked)           | 38      |
| RiskAssessment individuals            | 352     |
| SWRL reasoning rules                  | 13      |
| Semantic mapping individuals          | 2,824   |
| XAI output individuals per VP         | 8       |
| Materialized reasoning assertions     | 19,671  |

Source: direct `rdflib` query of the consolidated global ontology (§VIII-I).

#### A. Overall Architecture

RiskOnto’s architecture comprises **seven layers**, as illustrated in Fig. 1: input source ingestion (Layer 1), parallel scanner execution (Layer 2), normalization into a canonical Unified Vulnerability Schema (Layer 3), and semantic materialization into SUT-specific OWL individuals (Layer 4) feed into the shared, frozen RiskOnto knowledge hub (Layer 5). Layer 6 holds the 13 pre-materialized global rules (SI-7, SI-9, SI-11; 19,671 assertions from SI-7/SI-9 plus 847 VP-level `hasJustification` links from SI-11, executed offline once) and the SI-12 SUT-side activation rule (executed per SUT); Layer 7 delivers Executive, Technical and Forensic Audit reports via SPARQL queries over the reasoned graph [5].

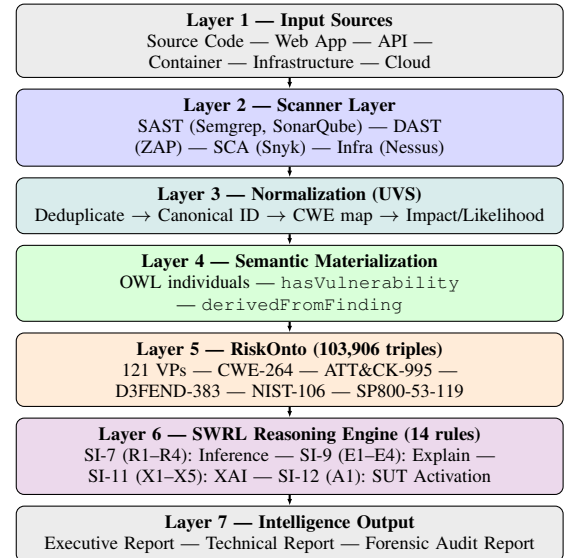


Fig. 1: RiskOnto Seven-Layer Architecture. Any System Under Test integrates via Layers 1–4; the RiskOnto (Layer 5) and Reasoning Engine (Layer 6) are shared across all SUTs without modification.

## B. RiskOnto Core Ontology

The core ontology is implemented in OWL 2 DL and defines **123 classes** organized into five functional domains:

- 1) **Asset Domain** (44 subclasses of Asset, e.g. Host, Application, Database, Container, CloudService, NetworkDevice, SourceCodeRepository). Assets are the protected resources linked to vulnerability findings via hasVulnerability.
- 2) **Vulnerability Domain:** VulnerabilityProfile is one of 14 sibling subclasses of Vulnerability (alongside InjectionVulnerability, AuthorizationVulnerability, AuthenticationVulnerability, APIVulnerability, AILLMVulnerability and 9 others), not their superclass. Each of the 121 VulnerabilityProfile individuals is *multi-typed*: it carries rdf:type VulnerabilityProfile (a reusable cross-framework anchor) together with one category subclass (e.g., VulnProfile\_SQL\_Injection is typed both VulnerabilityProfile and InjectionVulnerability), pre-mapped to CWE, ATT&CK, NIST and MITRE D3FEND.
- 3) **Risk Domain:** ThreatScenario, RiskAssessment, RiskLevel (CriticalRisk, HighRisk, MediumRisk, LowRisk, VeryLowRisk). 352 RiskAssessment individuals are pre-populated for all VP-asset combinations.
- 4) **Knowledge Source Domain:** AttackTechnique (995), Mitigation (37+), D3FENDTechnique (383), CWE (264), NISTSubcategory (106), Control (119).
- 5) **XAI Domain:** RiskJustification, MitigationJustification, ComplianceJustification, RecommendationStatement, RootCauseExplanation, EvidenceStatement and ImpactExplanation (seven types, linked to their VP via hasJustification, populated by the SI-11 rule set); DefenseJustification (an eighth, Mitigation-scoped type, also SI-11); and ReasoningTrace (a ninth, VP-linked type via the separate hasReasoningTrace property, generated by the SI-9 sublayer rather than SI-11) (§IV-D).

## C. Key Properties and Semantic Relationships

RiskOnto defines **70 object properties** and **24 datatype properties**. Table VIII lists the core properties that drive the reasoning chain.

The following OWL snippet illustrates a VulnerabilityProfile individual as stored in the RiskOnto ontology using current property names:

## D. Risk Assessment Model

RiskOnto implements an **ordinal risk-prioritization model**, informed by NIST SP 800-30 Rev 1's [10] likelihood-

TABLE VIII: Core RiskOnto Object Properties

| Property               | Domain                                          | Range                    | Layer               |
|------------------------|-------------------------------------------------|--------------------------|---------------------|
| mappedToCWE            | VP                                              | CWE                      | Asserted            |
| recommendedMitigation  | CWE                                             | Mitigation               | Asserted (R3 input) |
| exploitableByTechnique | VP                                              | AttackTechnique          | Asserted            |
| hasVulnerability       | Asset                                           | VP                       | Asserted            |
| supportsSubcategory    | Mitigation                                      | NISTSubcategory          | Asserted (R1 input) |
| affectsSubcategory     | VP                                              | NISTSubcategory          | SI-7 R1             |
| affectsFunction        | VP                                              | Function                 | SI-7 R2             |
| recommendedFor         | Mitigation                                      | VP                       | SI-7 R3             |
| recommendedD3FEND      | D3FENDTech                                      | VP                       | SI-7 R4             |
| explainsMitigation     | VP                                              | Mitigation               | SI-9 E1             |
| explainsDefense        | Mitigation                                      | D3FENDTech               | SI-9 E2             |
| explainsComplianceGap  | VP                                              | NISTSubcategory          | SI-9 E3             |
| explainsRisk           | VP                                              | CWE                      | SI-9 E4             |
| hasJustification       | VP                                              | XAI individual           | SI-11               |
| derivedFromFinding     | ThreatScenario / EvidenceStatement <sup>†</sup> | CanonicalSecurityFinding | SI-11               |

```

<!-- VulnProfile_SQL_Injection (abridged, RiskOnto) -->
<owl:NamedIndividual
  rdf:about="riskonto:VulnProfile_SQL_Injection">
  <rdf:type
    rdf:resource="riskonto:VulnerabilityProfile"/>
  <rdfs:label>SQL Injection</rdfs:label>
  <riskonto:mappedToCWE rdf:resource="riskonto:CWE-89"/>
  <riskonto:exploitableByTechnique
    rdf:resource="riskonto:T1190"/>
  <!-- SWRL-inferred (SI-7 R1, pre-materialized) -->
  <riskonto:affectsSubcategory
    rdf:resource="riskonto:PR_PS_03"/>
  <!-- XAI (SI-11 X1, pre-materialized) -->
  <riskonto:hasJustification
    rdf:resource="riskonto:VulnProfile_SQL_Injection_RJ"/>
</owl:NamedIndividual>

```

Fig. 2: RiskOnto OWL snippet: VulnProfile\_SQL\_Injection with verified property names and pre-materialized SWRL-inferred assertions. [5]

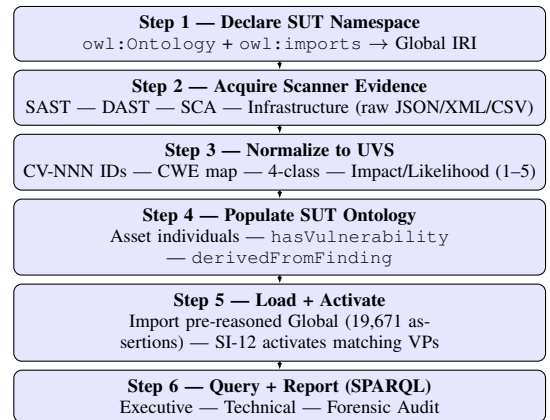


Fig. 3: RiskOnto SUT Integration Pipeline

and-impact framing and aligned with ISO 31000:2018's [22] risk identification/analysis/evaluation phases; the 1–5 scales, their multiplication, and the five-tier taxonomy are RiskOnto design choices, not standard-mandated requirements. For each ThreatScenario (a VulnerabilityProfile–AssetType pair), the ontology creates a RiskAssessment individual with four properties:

$$\text{RiskScore} = \text{Impact} \times \text{Likelihood}; \quad \text{Impact, Likelihood} \in \{1, \dots, 5\} \quad (1)$$

where the composite score is mapped to one of five criticality tiers. Table IX shows the tier classification; the ontology uses named RiskLevel individuals (CriticalRisk, HighRisk, etc.) linked via hasRiskLevel.

TABLE IX: RiskOnto Risk Tier Classification (5-tier)

| RiskLevel Individual | RiskScore Range | criticalityValue |
|----------------------|-----------------|------------------|
| CriticalRisk         | 21 – 25         | Critical         |
| HighRisk             | 15 – 20         | High             |
| MediumRisk           | 9 – 14          | Medium           |
| LowRisk              | 5 – 8           | Low              |
| VeryLowRisk          | 1 – 4           | Very Low         |

RiskScore = Impact × Likelihood on a 5×5 ordinal matrix (each dimension 1–5). This tier boundary scheme is a manuscript-defined classification layer over the numeric riskScoreValue; it is not itself a stored ontology fact. impact=5, likelihood=5 → score=25 → CriticalRisk (“Critical”); impact=4, likelihood=4 → score=16 → HighRisk (“High”).

The ontology contains **352 RiskAssessment individuals** covering all 121 VulnerabilityProfile archetypes across representative AssetType scenarios. Each assessment stores impact, likelihood (integers 1–5) and their product riskScoreValue (range 1–25) directly in the OWL ABox. **The current 352-individual RiskAssessment population instantiates only the top two tiers** (HighRisk: 229; CriticalRisk: 123; none below riskScoreValue = 16), a dataset-population fact, not an absence of the lower three tiers from the ontology which are used elsewhere.

**Impact and Likelihood Assignment.** RiskOnto provides the ontology-level representation for risk assessment, including Impact, Likelihood, RiskScore and the five-level risk classification described above. In the current WebGoat SUT integration, impact and likelihood values for each of the 43 canonical findings are populated through a **preliminary severity-to-risk mapping**: a categorical severity label (Critical, High, Medium, Low or Informational) drawn from scanner evidence is looked up in a fixed table whose five (impact, likelihood, riskScoreValue) triples were manually chosen placeholders, not derived from CVSS or any external scoring standard that assigns the corresponding triple per finding, e.g., “High” → (4, 4, 16). Lookup of an already-classified finding is automated and deterministic, but the table’s own values are manually assigned, coarse (five buckets), not a CVSS-subscore computation, and not manually reviewed by a security analyst. CVSS scores/vectors were available for 77 of the 273 raw observations (all from Snyk; the other four streams report no CVSS field) and were retained in the normalized data, but they were not

consumed by the current risk-scoring pipeline and therefore did not determine the assigned impact, likelihood or risk score. The ontology’s own description annotation on each of these 43 RiskAssessment individuals states explicitly that the values are provisional pending a more rigorous scoring pass. **This study does not claim that this mapping constitutes a validated, automated risk-scoring methodology.** Its purpose in the present work is to demonstrate the end-to-end *representation and propagation* of risk information through the semantic reasoning architecture, that a finding’s impact, likelihood and composite score are asserted, correctly classified into the five-tier taxonomy and retrievable alongside the rest of the reasoning chain is not to validate a new quantitative risk-scoring algorithm. For SQL Injection (CV-040), this mechanism yields impact = 4, likelihood = 4, riskScoreValue = 16 and criticalityValue = “High,” as shown in Table IX. The 352 global RiskAssessment individuals are likewise stored, asserted values (riskScoreValue = impact×likelihood holds for all 352/352). **No genuine CVSS-attribute-to-1–5 conversion exists anywhere in the accessible codebase** for either context, and **none of the 13 global SWRL rules performs the impact–likelihood multiplication**: the score is always a pre-computed ABox fact, and hasRiskLevel is an asserted link from a one-time table lookup; the ontology *represents and associates* the score with its RiskLevel interval, it does not *validate* it. Future work will replace this preliminary mapping with a methodology incorporating contextual asset value, exploitability and business impact.

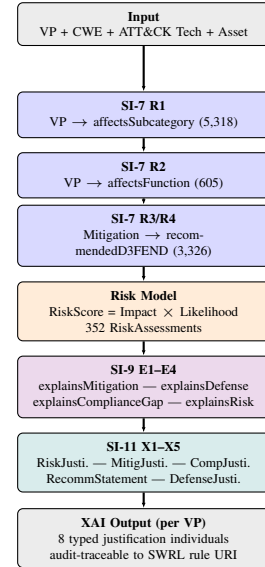


Fig. 4: RiskOnto SWRL Reasoning Flow

## VI. CAPABILITY MATURITY MODEL (CMM) IN CYBERSECURITY

The Capability Maturity Model (CMM) provides a structured approach to assess and improve organizational process

maturity, from ad hoc and reactive practices to disciplined, measured and continuously improving ones; CMM concepts are widely adopted in cybersecurity to evaluate current capability and plan improvement [16]. The NIST CSF’s **Govern** (GV) function establishes an organization’s cybersecurity risk management strategy and provides the strategic context for the other five CSF functions (Table III) [1]; CMM maturity tracking directly supports GV’s objectives of strategic alignment, continuous improvement and integration with enterprise risk management [16]. Fig. 5 and Table X show how RiskOnto’s capabilities map to each of the five CMM levels, adapted from the HC3 maturity-model briefing [6]: from surfacing inconsistent defenses (Level 1), through reusable mapped controls (Level 2), ontology-driven defined relationships (Level 3) and measured risk scoring (Level 4), to continuous, evidence-based structured semantic justification (Level 5). The Streamlit dashboard [18] presents these outputs for technical, managerial and executive stakeholders, translating NIST CSF Subcategories into MITRE D3FEND-mapped actionable controls [9].

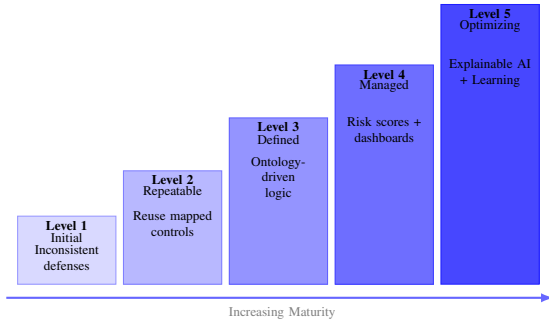


Fig. 5: RiskOnto and Capability Maturity Model (CMM)

TABLE X: How RiskOnto Supports CMM Levels

| CMM Level            | How RiskOnto Helps                                                                                    |
|----------------------|-------------------------------------------------------------------------------------------------------|
| Level 1 – Initial    | Reveals inconsistent or missing defense plans.                                                        |
| Level 2 – Repeatable | Enables reuse of mapped controls and mitigation patterns.                                             |
| Level 3 – Defined    | Provides defined relationships (Threat → Control → Tool) via the ontology.                            |
| Level 4 – Managed    | Risk scores and inference-derived relationships support measured risk and framework-outcome tracking. |
| Level 5 – Optimizing | Structured semantic justification supports evidence-based, continuous adaptation.                     |

## VII. QUALITY EVALUATION OF *RiskOnto*

RiskOnto was evaluated along three dimensions: (1) structural completeness, assessed through OWL class and property counts extracted via direct rdflib 7.6.0 graph traversal; (2) reasoning coverage, measured by SWRL assertion materialization; and (3) ontological soundness, assessed via the OOPS! pitfall scanner [21]. The ontology is authored to the OWL 2 DL profile and was checked for consistency with the HermiT 1.4.3.456 reasoner in Protégé 5.6 [28], which reported no inconsistencies (see §IV-E). Table XI summarizes the structural and population metrics of the RiskOnto assessed using OntoMetrics [27].

TABLE XI: RiskOnto Reusable Statistics

| Metric                                        | Value   | Source                        |
|-----------------------------------------------|---------|-------------------------------|
| Total RDF triples                             | 103,906 | rdflib 7.6.0 direct parse     |
| OWL 2 DL classes                              | 123     | rdflib 7.6.0 direct parse     |
| Object properties                             | 70      | rdflib 7.6.0 direct parse     |
| Datatype properties                           | 24      | rdflib 7.6.0 direct parse     |
| VulnerabilityProfile archetypes               | 121     | rdflib 7.6.0 direct parse     |
| RiskAssessment individuals                    | 352     | rdflib 7.6.0 direct parse     |
| Cross-framework mapping individuals           | 2,824   | rdflib 7.6.0 direct parse     |
| SWRL rules (13 global + 1 SUT-side)           | 14      | SWRL rule file                |
| Global materialized assertions (R1–R4, E1–E4) | 19,671  | rdflib 7.6.0 (post-execution) |

**Structural Scale.** The ontology encodes **103,906 RDF triples** across **123 OWL 2 DL classes** organized in five functional domains (Asset, Vulnerability, Risk, Knowledge Source, XAI; see §V). **70 object properties** and **24 datatype properties** express semantic relationships between vulnerability findings, cybersecurity frameworks, risk assessments and XAI outputs. All 70 object properties carry explicit `rdfs:domain` and `rdfs:range` axioms. The **121 VulnerabilityProfile archetypes** and **2,824 cross-framework mapping individuals** form the reusable knowledge layer shared across all Systems Under Test without modification.

**Reasoning Coverage.** The 13 global SWRL rules in three sublayers (SI-7: inference; SI-9: explanation; SI-11: XAI) materialized, once, offline, during ontology construction: SI-7/SI-9 (R1–R4, E1–E4) produced **19,671 semantic assertions** and SI-11 (X1–X5) produced **847 VP-level hasJustification links** to typed XAI justification/explanation individuals; the SI-12 rule performs SUT-side profile activation separately at SUT-population time, replacing manual annotation for each new SUT. The 352 RiskAssessment individuals cover all 121 VP archetypes across representative asset scenarios, storing `impact`, `likelihood` (integers 1–5) and `riskScoreValue` (1–25) in the OWL ABox.

**Ontological Soundness.** The ontology is authored to the OWL 2 DL profile; DL-consistency checking via HermiT 1.4.3.456, started through Protégé, reported no inconsistencies (§IV-E). This is distinct from, and does not substitute for, independent verification of the materialized assertion counts themselves, which is performed separately via rdflib (§VIII-I). OOPS! evaluation found no blocking pitfalls. P41 (missing license declaration) was triggered as a false positive: the ontology header declares both `dcterms:license` and `cc:license` pointing to CC BY 4.0 [21].

### A. Reasoning Output and Intended Analyst Use

**Counts measure materialization coverage, not semantic correctness or human usefulness (§VIII-H).** The 19,671 materialized assertions are intended as retrievable cybersecurity intelligence for the following analyst-facing purposes, not evidence that those purposes have been empirically validated:

- **Framework-outcome association (5,318 affectsSubcategory):** SWRL rule R1 identifies the NIST CSF 2.0 subcategories potentially

TABLE XII: RiskOnto Capability Coverage Summary

| Capability                         | Evidence                                                                                                                                       |
|------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| Vulnerability archetypes           | 121 VulnerabilityProfile individuals                                                                                                           |
| Knowledge sources integrated       | 5 (CWE, ATT&CK, D3FEND, NIST CSF, SP 800-53)                                                                                                   |
| Automated reasoning                | 13 global rules (offline): R1-R4/E1-E4 → 19,671 assertions; X1-X5 → 847 hasJustification links; 1 SUT-side activation rule (SI-12)             |
| Risk coverage                      | 352 RiskAssessment individuals (all VPs)                                                                                                       |
| XAI output types                   | 7 VP-scoped (via X1,X2,X4,X5 + Python enrichment, 847 hasJustification links) + 1 Mitigation-scoped (X3, DefenseJustification, 42 individuals) |
| Scanner types supported            | 4 (SAST, DAST, SCA, Infrastructure)                                                                                                            |
| WebGoat normalization              | 273 raw → 166 CWE-eligible → 43 canonical                                                                                                      |
| WebGoat semantic workflow coverage | 43/43 canonical findings (100%) activate a VulnerabilityProfile and retrieve the associated semantic reasoning chain                           |

implicated per VP, replacing manual cross-reference with SPARQL-retrievable candidate associations.

- **Function-level reporting (605 affectsFunction):** SWRL rule R2 maps every VP to one or more CSF Functions (GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER) without manual aggregation.
- **Defensive countermeasure recommendations (3,326 recommendedD3FEND):** SWRL rule R4 links mitigation paths to MITRE D3FEND techniques, producing traceable defense recommendations alongside every finding.
- **Structured semantic justification output (847 hasJustification triples + 42 DefenseJustification):** Table XIII gives the fresh, per-type verification: 7 VP-scoped types (847 hasJustification links) plus 1 Mitigation-scoped type (X3, 42 individuals), inspectable from finding through rule to risk decision and framework-outcome association.

TABLE XIII: XAI Justification/Explanation Types: Fresh Graph Verification

| Type                    | Owner      | N   | Generation                   |
|-------------------------|------------|-----|------------------------------|
| RiskJustification       | VP         | 121 | X1, rule-linked              |
| MitigationJustification | VP         | 121 | X2, rule-linked              |
| DefenseJustification    | Mitigation | 42  | X3, rule-linked <sup>†</sup> |
| ComplianceJustification | VP         | 121 | X4, rule-linked              |
| RecommendationStatement | VP         | 121 | X5, rule-linked              |
| RootCauseExplanation    | VP         | 121 | Enrichment (X1)              |
| ImpactExplanation       | VP         | 121 | Enrichment (X4)              |
| EvidenceStatement       | VP         | 121 | Enrichment (X1,X2,X4)        |

**Scalability.** The RiskOnto’s 121 VulnerabilityProfile archetypes cover OWASP Top 10 and SANS CWE Top 25 categories; additional VPs are appended by adding VulnerabilityProfile individuals and mappedToCWE / exploitableByTechnique assertions without modifying SWRL rules or existing individuals. Multiple SUTs operate in isolated OWL namespaces enabling concurrent analysis without cross-contamination of reasoning outputs. Quantitative reasoning latency and memory

consumption benchmarks are reserved for future evaluation with a larger SUT corpus.

## VIII. VALIDATION: WEBGOAT CASE STUDY

To validate that RiskOnto’s integration pipeline generalizes to a real-world SUT, we instantiated the framework against **WebGoat 2025.4-SNAPSHOT** [23], an intentionally insecure Spring Boot web application maintained by OWASP. WebGoat was selected because (i) its vulnerability profile is documented and verifiable; (ii) it covers injection, authentication bypass, insecure deserialization, path traversal and CSRF, spanning the full range of RiskOnto’s 121-VP taxonomy; (iii) its Java codebase is analyzable by SAST, SCA and DAST tools simultaneously; and (iv) it is a legal, purpose-built scanning target. This section evaluates the functional execution and traceability of the RiskOnto workflow on WebGoat and does not claim population-level generalizability. The current evaluation focuses on OWL 2 DL consistency checking, structural mapping verification, canonicalization auditing, rule-derived workflow coverage, and end-to-end traceability. Relation-level precision, recall, F1, inter-rater agreement and human-centered usefulness have not been established in the present study and remain subjects for future expert-based evaluation; comparative baselines and runtime/memory performance benchmarking are likewise not part of the current evaluation (§VIII-I).

### A. Scanner Coverage and Normalization

Four security analysis tools were deployed against WebGoat 2025.4-SNAPSHOT in a controlled local environment; SonarQube contributes two distinct finding categories (Issues, Security Hotspots), giving five output categories in total across the four tools. Table XIV summarizes coverage.

TABLE XIV: WebGoat SUT: Scanner Coverage and Normalization

| Scanner                                   | Type | Version      | Finding IDs           | Raw          |
|-------------------------------------------|------|--------------|-----------------------|--------------|
| Semgrep                                   | SAST | 1.161.0      | SEM-001-017           | 17           |
| SonarQube Issues                          | SAST | 9.9.8.100196 | SQI-001-100           | 100          |
| SonarQube Hotspots                        | SAST | 9.9.8.100196 | SQH-001-069           | 69           |
| Snyk (SCA)                                | SCA  | 1.1304.1     | SNYK-001-077          | 77           |
| OWASP ZAP                                 | DAST | 2.17.0       | ZAP-001-010           | 10           |
| <b>Total raw outputs</b>                  |      |              |                       | <b>273</b>   |
| <b>Outside CWE canonicalization scope</b> |      |              | no CWE mapping        | <b>107</b>   |
| <b>CWE-representable (eligible)</b>       |      |              |                       | <b>166</b>   |
| <b>Canonical findings</b>                 |      |              | CV-001-043            | <b>43</b>    |
| <b>Semantic workflow coverage</b>         |      |              | activates $\geq 1$ VP | <b>43/43</b> |

Fig. 6 summarizes the five-stage processing pipeline. Of the 273 raw tool outputs, 166 carry a CWE-representable security weakness and are canonicalized by CWE identity into the 43 CanonicalSecurityFinding individuals (CV-001-CV-043) that enter the semantic reasoning workflow; this is a **74% reduction within the CWE-representable population** ( $(\frac{166-43}{166}) \times 100 \approx 74\%$ ), or  $\approx 84\%$  relative to

the full 273 raw outputs ( $((\frac{273-43}{273}) \times 100 \approx 84\%)$ ) once the 107 out-of-scope outputs are counted in the denominator. The remaining 107 raw outputs are predominantly SonarQube code-quality observations (`CODE_SMELL`, 92 of 107) together with generic bug findings, hotspot “other” findings and informational OWASP ZAP alerts carry no CWE mapping and are **outside the current CWE-based canonicalization scope**; they remain part of the raw scanner inventory but do not become `CanonicalSecurityFinding` individuals in the SUT ontology. Several of the 107 carry high severity labels from their source tool (20 rated “Critical” by SonarQube’s own maintainability-severity scale); their exclusion reflects the current model’s CWE-centred representational scope, not their severity, relevance or correctness; they are not deleted, ignored, or judged harmless, and extending the framework to represent additional non-CWE finding categories is future work (§VIII-E).

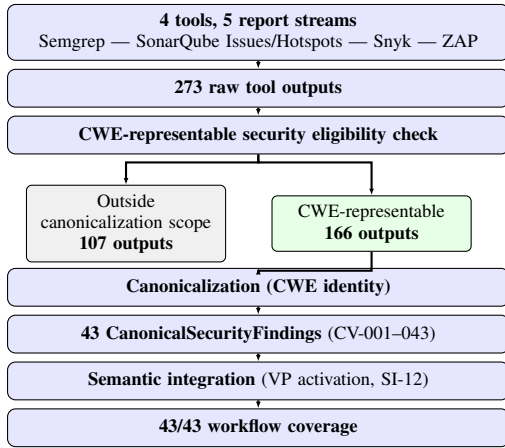


Fig. 6: WebGoat finding-processing pipeline: eligibility scoping and canonicalization are distinct stages. The 107 out-of-scope outputs are not merged into the 43 canonical findings and do not participate in workflow coverage.

Table XV defines the UVS fields used to produce each canonical finding record. The artifact that produced the 43 canonical was determined by **CWE identity**. Scanner identity is preserved as *provenance* on the resulting canonical record (`sourceScanner`, `sourceCount`) but does not gate whether two raw findings merge. Findings with no CWE mapping are routed to a single shared, unpublished group rather than merged into any of the 43. The algorithm is:

```

for f in RawFindings:
    cwe = extractOrMapCWE(f)
    key = catalogLookup(cwe) # shared "no-CWE"
                                # key if cwe absent
    if exists c: c.key == key:
        merge(f, c) # append (scanner, id)
                    # as provenance to c
    else:
        new(f, key)
  
```

Only groups keyed by a real CWE are reported as `CanonicalSecurityFinding` individuals; the single no-CWE group (107 raw outputs, §VIII) is excluded from this

reporting boundary, not from the algorithm itself. For example, canonical finding CV-040 (SQL Injection) merges 22 raw findings from two distinct scanners (11 Semgrep, 11 SonarQube Hotspots) purely on shared CWE-89; this is confirmed directly in the SUT ontology’s own `fromScanner/sourceCount` fields for CV-040. **Current limitation:** the canonicalization step, as implemented, does not retain file, line, URL, endpoint or parameter information, so it cannot distinguish two genuinely distinct findings that happen to share a CWE at different code locations or endpoints, such findings are collapsed into a single canonical record, which understates the true finding count and loses per-location remediation specificity. This is a real, demonstrated limitation of the current WebGoat integration pipeline, not a hypothetical concern: the 22 raw findings merged into CV-040 include multiple distinct Semgrep detection patterns, indicating more than one underlying source location. A context-aware canonical identity that additionally incorporates asset, endpoint/location, parameter or evidence signature e.g., `CanonicalKey = f(VulnerabilityType, CWE, Asset, Location, Parameter)` would resolve this, but is not implemented in the current pipeline and is identified here as future work, not a present capability.

TABLE XV: Unified Vulnerability Schema (UVS) Field Specification

| Field                        | Description                                                                                                                                                                                |
|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>vulnerabilityId</code> | Canonical finding ID (CV-NNN format; NNN 001–043)                                                                                                                                          |
| <code>sourceScanner</code>   | Scanner tool(s) that produced the merged raw findings (provenance; does not gate merging)                                                                                                  |
| <code>sourceCount</code>     | Number of raw findings merged into this canonical record                                                                                                                                   |
| <code>cweId</code>           | CWE identifier extracted or mapped from scanner output; the sole current canonicalization key                                                                                              |
| <code>severity</code>        | Normalized severity class: Critical, High, Medium, Low, Informational                                                                                                                      |
| <code>impact</code>          | Integer 1–5; assigned via the severity-to-risk mapping described in §V-D, not CVSS-subscore-derived                                                                                        |
| <code>likelihood</code>      | Integer 1–5; assigned via the same severity-to-risk mapping                                                                                                                                |
| <code>confidence</code>      | Float, one of {0.5, 0.7, 0.9}; scanner-corroboration heuristic (0.5 for 1 corroborating scanner, 0.7 for 2, 0.9 for 3+), not an alignment score with the VP archetype and not STIX-derived |
| <code>evidence</code>        | Scanner tool + finding ID cross-reference (e.g., SEM-001, SQH-032)                                                                                                                         |
| <code>asset</code>           | Target asset identifier (hostname, URL, file path); not currently used in canonicalization                                                                                                 |
| <code>timestamp</code>       | Scan execution datetime (ISO 8601)                                                                                                                                                         |

All 43 canonical findings activate at least one RiskOnto `VulnerabilityProfile` via SI-12 and retrieve the associated semantic reasoning chain, reported here as *semantic workflow coverage*, distinct from mapping correctness (§VIII-E).

## B. Reasoning Outcomes

For each of the 43 canonical findings, the SI-12 activation rule binds the finding to at least one VP archetype, through which it inherits the pre-materialized NIST CSF 2.0 framework-outcome associations, ATT&CK threat-technique mappings, mitigation recommendations and MITRE D3FEND defensive-technique mappings already present in the global

graph. Table XVI summarizes the result, 12 of the 43 findings activate more than one VP archetype, discussed in Table XIX.

TABLE XVI: WebGoat Reasoning Outcomes Summary

| Metric                                 | Result                     |
|----------------------------------------|----------------------------|
| Raw scanner findings                   | 273                        |
| CWE-eligible for canonicalization      | 166                        |
| Canonical findings after normalization | 43                         |
| Findings activating $\geq 1$ VP        | 43                         |
| Findings activating $> 1$ VP           | 12                         |
| Semantic workflow coverage             | 43/43                      |
| Observed mapping limitation            | CV-043 over-generalization |

Workflow coverage is a structural-activation measure, not a semantic-correctness measure (§VIII-E).

### C. SQL Injection Traceability Chain

Fig. 7 illustrates the complete end-to-end traceability chain for SQL Injection (CWE-89), the highest-evidence finding in the dataset (22 raw findings from two scanners). All values are verified from the OWL file via rdflib SPARQL query.

### D. Validation Outcomes

The WebGoat integration confirmed three core claims:

- 1) **Scanner-agnostic normalization:** Four heterogeneous scanner formats were unified without loss of finding identity or multi-scanner co-detection evidence (SQL Injection: 22 raw findings from 2 scanners).
- 2) **Single-import activation:** One `owl:imports` declaration was sufficient to inherit the full pre-materialized global reasoning chain, and the SI-12 rule bound all 43 canonical findings to their matching VP archetype(s) without modifying RiskOnto.
- 3) **SUT-independent reuse of the global reasoning output:** The 13 pre-materialized global rules' output, all 121 VP archetypes and all framework knowledge (ATT&CK, MITRE D3FEND, NIST) were consumed as-is by a new SUT with no schema extension required.

### E. Semantic Workflow Coverage and Its Scope

All 43 canonical findings (100%) activate at least one VulnerabilityProfile via the SI-12 rule and, through that activation, retrieve the associated ATT&CK technique mapping, MITRE D3FEND-mapped mitigations, NIST CSF 2.0 framework-outcome mapping and XAI justification chain independently. Coverage and correctness are deliberately kept as separate questions: structural activation does not imply that every individual ATT&CK, D3FEND or NIST CSF relationship reached is semantically correct or contextually appropriate for that finding. Correctness at the level of individual mappings is assessed separately, on a bounded representative sample, in Table XIX, including a retained counter-example (CV-043) in which full activation co-occurs with an observed over-generalization. 100% workflow coverage should not be read as 100% mapping correctness.

A separate scope limitation: the current CWE-centred workflow excludes the 107 raw outputs without a CWE-representable weakness (mostly SonarQube code-quality/informational findings) from the 43-finding population

over which 43/43 is reported, not a judgment that they are unimportant, but a representational-scope boundary; extending canonicalization to these non-CWE categories is future work.

### F. Comparative Validation Discussion

Table XVII contrasts a conventional manual cybersecurity risk assessment workflow against RiskOnto's semantic automation approach for an equivalent scope of analysis (four scanner types, SQL Injection focus). The comparison is process-oriented; no timing experiments were conducted and no performance claims are made. RiskOnto acts as a semantic automation layer that reduces analyst effort in cross-framework correlation, it is not a replacement for domain expertise or organizational governance processes [10].

TABLE XVII: Manual Risk Assessment vs. RiskOnto

| Activity                      | Manual Approach                                              | RiskOnto                                                                     |
|-------------------------------|--------------------------------------------------------------|------------------------------------------------------------------------------|
| CWE identification            | Per-finding lookup                                           | mappedToCWE (121 VPs pre-linked)                                             |
| ATT&CK mapping                | Manual table lookup                                          | Asserted exploitableByTechnique (995 techniques)                             |
| NIST CSF mapping              | Manual subcategory search                                    | SWRL R1/R2: 5,318 + 605 assertions auto-derived                              |
| MITRE D3FEND mapping          | Manual technique lookup                                      | SWRL R4: 3,326 recommendedD3FEND                                             |
| Explainability output         | Not standardized                                             | SI-11: 847 typed structured-justification records (SWRL-grounded)            |
| Traceability                  | Spreadsheet-based                                            | SPARQL-queryable 7-step chain                                                |
| Repeatability                 | Analyst-dependent                                            | Deterministic OWL reasoning                                                  |
| Framework-outcome association | Standard-by-standard                                         | 45 CSF subcategories auto-flagged (CWE-89)                                   |
| Cross-framework correlation   | Manual lookup across ATT&CK, CWE, NIST and D3FEND separately | Auto-derived via OWL property chains; single SPARQL query over unified graph |

Manual approach characteristics reflect typical unassisted workflow per NIST SP 800-30 [10].

### G. Validation Scope: What This Study Demonstrates

RiskOnto is not evaluated in this study as a vulnerability classifier and does not itself decide whether a code location is vulnerable; that decision is made upstream by the four external scanners. RiskOnto's own task begins after a scanner has already produced a finding, and consists of normalization, CWE-based canonicalization, VulnerabilityProfile activation, semantic-reasoning-chain retrieval, risk-tier classification and structured justification.

**Evaluation scope.** Classification metrics (precision, recall, F1-score, specificity) were not computed because RiskOnto is not formulated here as a classifier against an independently labelled ground-truth dataset; instead, the evaluation examines whether scanner findings normalize into a common representation, connect to the corresponding security knowledge, and trace through the reasoning workflow, structural and semantic coverage, not classification accuracy. Relation-level precision/recall/F1 would require an independently established expert reference set, Cohen's  $\kappa$  would additionally require multiple independent evaluators, and precision@5 requires an implemented ranking procedure; none of these was built at

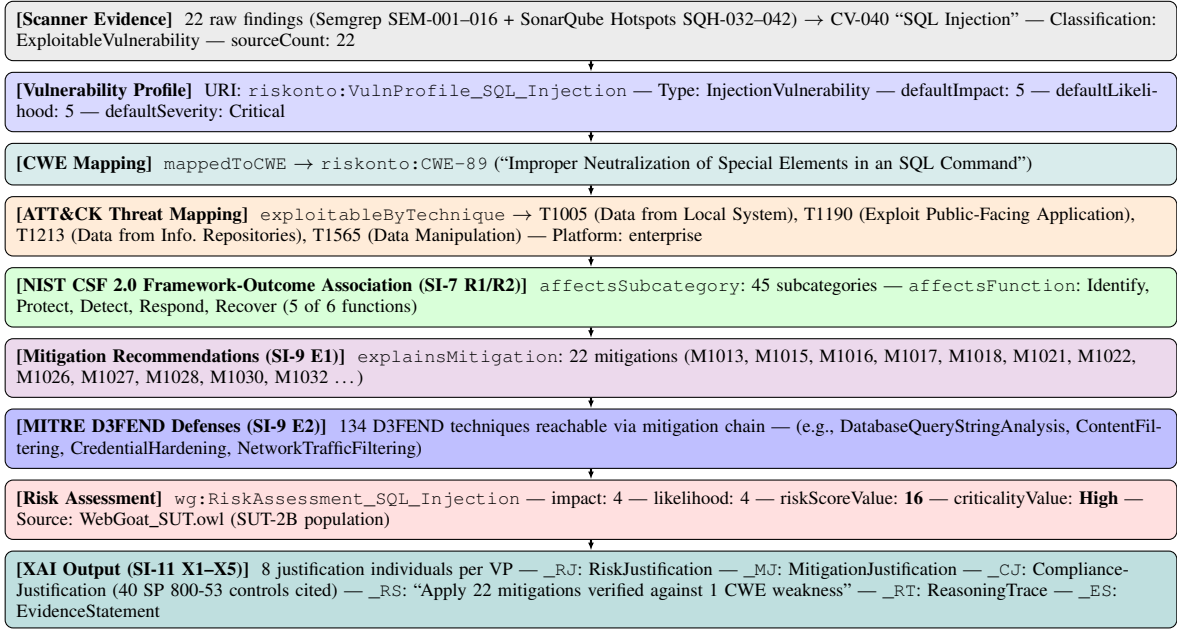


Fig. 7: RiskOnto Threat–Risk–Framework–Outcome–Mitigation Traceability Chain: SQL Injection (CWE-89, WebGoat 2025.4-SNAPSHOT).

the current stage of this paper, so these measures are **not evaluated here**.

Rather than reject the request for stronger validation evidence, this paper adds four explicit validation questions (Table XVIII), answered using only existing WebGoat and ontology evidence, no additional SUT, expert panel or synthetic experiment was introduced.

#### H. Scope of the Explainability Claim

The XAI justification individuals described in §IV-D provide **structured semantic justification**: each is a typed OWL individual carrying `derivedFromRule` provenance to a named SWRL rule URI, is SPARQL-retrievable, and forms an auditable, machine-readable reasoning trace from a finding to its supporting evidence. This is a structural, technically verifiable property of the ontology. **This study does not include a controlled user study evaluating human comprehensibility, usability, trust or analyst decision quality**, and does not claim that the XAI output has been shown to be understandable or useful to human analysts in practice. Where this manuscript refers to “explainability,” it refers specifically to this structured, provenance-aware, machine-traceable justification capability, not to a human-validated explanation quality. A controlled analyst evaluation (e.g., a task-based comparison or think-aloud protocol with practicing security analysts) is identified as future work.

#### I. Reproducibility

Table XX reports what is independently verifiable about the execution environment and pipeline for this paper. Values reported as “not available” are stated as such rather than estimated.

#### J. Practical Deployment Workflow

Deploying RiskOnto against a new SUT follows the same six-step pipeline shown in Fig. 3, instantiating each canonical finding as an OWL individual linked to the shared knowledge base via a single `owl:imports` declaration; no SWRL rules are re-executed at this step (§IV-E). SPARQL queries then extract governance-relevant outputs, which the Streamlit dashboard [18] aggregates into framework-outcome-association and executive-level risk reports. The pipeline is deterministic and repeatable: analysts interact with it only at scanner execution and report interpretation.

### IX. CONCLUSION

In this paper, we introduced **RiskOnto**, an ontology-driven framework for threat modeling and risk reasoning within the cybersecurity domain.

RiskOnto’s six contributions (N1–N6, §II-G) combine a five-source knowledge graph, a scanner-agnostic normalization pipeline, an offline-materialized SWRL rule layer and a formalized XAI justification layer into a single reusable architecture that requires no modification to integrate a new SUT. A central contribution is the semantic bridge between NIST CSF 2.0 functions and concrete MITRE D3FEND defensive techniques, associating high-level framework outcomes with candidate security controls without manual cross-reference [18].

As established in Section II (Table II), RiskOnto extends prior ontology-based risk assessment approaches (OnToRisk [24], Vålja et al. [14], Al Hammouri & Al Bataineh [7]) by providing a continuous, SWRL-specified semantic chain from a vulnerability archetype through CWE,

TABLE XVIII: Validation Questions: What the WebGoat Evidence Demonstrates and Does Not Demonstrate

| VQ  | Question                                                                            | Evidence                                                                              | Demonstrates                                                                     | Does Not Demonstrate                                                                                                                     |
|-----|-------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|----------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| VQ1 | Normalize heterogeneous scanner output into one semantic representation?            | 273 raw (5 streams) → 166 CWE-eligible → 43 canonical, uniform UVS schema             | Scanner outputs are normalized into one common semantic schema                   | Preservation of every distinct real-world finding (§VIII: same-CWE, different-location findings collapse; non-CWE findings out of scope) |
| VQ2 | Activate VulnerabilityProfiles and expose semantic relationships?                   | activatesProfile: 43/43, ≥1 link each                                                 | Every finding retrieves its full reasoning chain (ATT&CK, D3FEND, NIST CSF, XAI) | That the activated VP is always the most appropriate one (CV-043, Table XIX, is a counter-example)                                       |
| VQ3 | Provide traceable paths from evidence to cybersecurity/defensive knowledge?         | Five sampled end-to-end traces; zero broken links; relations remain provenance-linked | Traceability across the reasoning chain, reproducible for the sample             | Semantic correctness of every inferred mapping (only a sample checked, Table XIX)                                                        |
| VQ4 | Support reproducible retrieval of risk, mapping, provenance and justification data? | Structural figures re-derived from the live ontology, matching prior results exactly  | Query results are stable and reproducible on the current ontology                | Reproducibility across ontology versions; reproducibility of the upstream scoring step, which is a documented placeholder (§V-D)         |

TABLE XIX: Representative Semantic Mapping Verification (5 of 43 WebGoat findings)

| Finding                | CWE                 | VP Activated        | Outcome                                                               |
|------------------------|---------------------|---------------------|-----------------------------------------------------------------------|
| CV-040 SQL Inj.        | CWE-89              | SQL_Injection       | Coherent mapping; one weaker technique citation (T1005)               |
| CV-020 CSRF            | CWE-352             | CSRF                | Coherent mapping; one looser technique citation (T1078)               |
| CV-001 Clickjacking    | CWE-1021 (+5)       | Header_Missing      | Partial semantic overlap; multi-CWE umbrella, weak technique citation |
| CV-023 Res. Exhaustion | CWE-770/400/674/789 | Rate_Limit          | Coherent mapping; one weak technique citation (T1078)                 |
| CV-043 Code Inj.       | CWE-94, CWE-20      | Code_Injection (+8) | <b>Over-generalization observed</b>                                   |

ATT&CK and D3FEND to NIST CSF 2.0 governance functions, a traceability path not formalized in existing published systems [4], [11]–[13]. RiskOnto is intended to complement existing risk assessment frameworks rather than replace them.

The WebGoat 2025.4-SNAPSHOT case study demonstrated functional feasibility: the deployment pipeline is scanner-agnostic and integrates without modifying the shared knowledge base; of 273 raw scanner observations, 166 were within the current CWE-based canonicalization scope and consolidated into 43 canonical security findings, all of which activated at least one VulnerabilityProfile and retrieved a traceable, machine-readable justification chain (structural workflow coverage), not a demonstration of semantic correctness for every inferred association. This study does not establish external validity beyond this single case study, correctness across arbitrary SUTs, effectiveness of the structured justification output for human analysts, or organizational or legal compliance status. The current canonicalization, deduplication and WebGoat risk-scoring mechanisms carry the scope limitations detailed in §VIII, §V-D and §VIII-H.

Future work includes expanding the VP library beyond 121 archetypes and extending canonicalization to non-CWE finding categories, alongside a concrete evaluation roadmap not undertaken in the present study, including: (1) *human expert semantic validation* of the inferred CWE, ATT&CK, NIST CSF, mitigation and D3FEND relations, ideally with at least two independent cybersecurity experts reviewing the 43

TABLE XX: Reproducibility Information

| Item                            | Value                                                                                                                                                                                                                              |
|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Authoritative ontology          | RiskOnto_global_v27_consolidated.owl (global); WebGoat_SUT_v27_reasoned.owl (SUT side)                                                                                                                                             |
| Ontology format                 | OWL 2 DL / RDF/XML (global); Turtle (SUT)                                                                                                                                                                                          |
| SWRL materialization mechanism  | Python/rdfliib-based forward-chaining emulation of rule antecedent-consequent patterns (§IV-E); generated the 19,671 R1–R4/E1–E4 assertions and the 847 X1–X5 hasJustification links                                               |
| OWL 2 DL consistency check      | HermiT 1.4.3.456                                                                                                                                                                                                                   |
| Query mechanism                 | rdflib SPARQL, read-only, over the static reasoned graph                                                                                                                                                                           |
| Library versions                | rdflib 7.6.0, Python 3.14.3                                                                                                                                                                                                        |
| Java                            | Version 25 (pom.xml, maven-compiler-plugin), required by the WebGoat/Maven build only                                                                                                                                              |
| Ontology editor / reasoner host | Protégé 5.x, used for ontology authoring/inspection and as the host application for the HermiT consistency check above; not used for SWRL materialization                                                                          |
| OS/hardware                     | Windows 11 Education, version 25H2, OS build 26200.9278, 64-bit OS / x64 processor; Intel Core Ultra 7 155H (1.40 GHz); 16 GB RAM (15.5 GB usable); NVIDIA RTX 500 Ada Generation Laptop GPU (4 GB) with integrated Intel Graphics |
| SUT version                     | WebGoat 2025.4-SNAPSHOT (development build following release v2025.3, commit d4238ab4, 2 Nov 2025)                                                                                                                                 |
| Scanner tool versions           | Semgrep 1.161.0 and OWASP ZAP 2.17.0; SonarQube server 9.9.8.100196; Snyk 1.1304.1                                                                                                                                                 |
| Execution procedure             | Global ontology construction (offline) → scanner evidence acquisition → normalization/canonicalization → SUT ontology population → SI-12 activation → SPARQL query/report                                                          |
| Input/output artifacts          | Global ontology; per-scanner raw reports; normalization CSV (273 rows); SUT ontology (asserted and reasoned variants)                                                                                                              |
| Repository                      | <a href="https://github.com/madelere/RiskOnto-v1/">https://github.com/madelere/RiskOnto-v1/</a> [5], publicly available.                                                                                                           |

canonical findings and disagreements resolved by adjudication; (2) *relation-level precision, recall and F1* against the resulting reference set; (3) *inter-rater agreement* (e.g., Cohen’s  $\kappa$ ) between experts; (4) a genuine *candidate-ranking mechanism* for mitigation recommendations (by path directness, provenance, SUT-context match and risk tier), evaluated via precision@5 only once implemented; (5) *multi-run performance evaluation* of offline materialization, SUT graph construction and SPARQL retrieval, with repeated runs, a warm-up run, and median/IQR runtime plus peak RSS memory; (6) *validation across additional public SUTs* (e.g., OWASP Juice Shop) to

assess external validity beyond WebGoat; and (7) *context-aware matching* to address the CWE-only over-generalization CV-043 demonstrates. None of (1)–(7) is claimed as completed in the present study. RiskOnto is available on GitHub under CC BY 4.0 [5].

## APPENDIX A: SWRL RULE FORMAL SPECIFICATION

The 13 global (offline, materialized-once) SWRL rules of the RiskOnto reasoning engine are specified below, grouped by functional sublayer. The 14th formally-declared rule, SI-12 (SUT-side activation, per-SUT rather than global), is described in §IV-E instead. Each rule below is identified by its canonical URI, `urn:swrl:rule:label`; headers give the *label* suffix only. The rule bodies are reproduced from verified OWL blank-node atom chains extracted from the ontology file [5]. Variable names follow the convention `?vp` (VulnerabilityProfile), `?t` (AttackTechnique), `?m` (Mitigation), `?sc` (NISTSubcategory), `?f` (Function, the ontology’s NIST CSF Function class), `?d` (D3FENDTechnique), `?cwe` (CWE).

### Sublayer SI-7 — Core Reasoning Rules (R1–R4)

#### R1 — SI7\_AffectsSubcategory

*Purpose:* Infer `affectsSubcategory` from the VP–Technique–Mitigation–Subcategory path. Produces 5,318 assertions.

```
Body:
  VulnerabilityProfile(?vp)
  ^ exploitableByTechnique(?vp, ?t)
  ^ AttackTechnique(?t)
  ^ mitigatedBy(?t, ?m)
  ^ Mitigation(?m)
  ^ supportsSubcategory(?m, ?sc)
  ^ NISTSubcategory(?sc)
Head:
  affectsSubcategory(?vp, ?sc)
```

#### R2 — SI7\_AffectsFunction

*Purpose:* Lift `affectsSubcategory` to CSF Function level. Produces 605 assertions.

```
Body:
  VulnerabilityProfile(?vp)
  ^ affectsSubcategory(?vp, ?sc)
  ^ NISTSubcategory(?sc)
  ^ belongsToFunction(?sc, ?f)
  ^ Function(?f)
Head:
  affectsFunction(?vp, ?f)
```

#### R3 — SI7\_RecommendedFor

*Purpose:* Derive mitigation recommendations directly from the VP–CWE–Mitigation chain (a per-CWE recommended-mitigation catalog relation, not routed through an AttackTechnique). Produces 505 assertions.

```
Body:
  VulnerabilityProfile(?vp)
  ^ mappedToCWE(?vp, ?cwe)
  ^ CWE(?cwe)
  ^ recommendedMitigation(?cwe, ?m)
  ^ Mitigation(?m)
Head:
  recommendedFor(?m, ?vp)
```

#### R4 — SI7\_RecommendedD3FEND

*Purpose:* Propagate D3FEND defensive technique recommendations via the Mitigation–D3FEND chain. Produces 3,326 assertions.

```
Body:
  Mitigation(?m)
  ^ recommendedFor(?m, ?vp)
  ^ VulnerabilityProfile(?vp)
  ^ implementedBy(?m, ?d)
  ^ D3FENDTechnique(?d)
Head:
  recommendedD3FEND(?d, ?vp)
```

### Sublayer SI-9 — Explainability Annotation Rules (E1–E4)

#### E1 — SI9\_E1\_ExplainMitigation

*Purpose:* Annotate VPs with a mitigation explanation predicate, derived via the same CWE–Mitigation catalog relation used by R3. Produces 2,437 assertions.

```
Body:
  VulnerabilityProfile(?vp)
  ^ mappedToCWE(?vp, ?cwe)
  ^ recommendedMitigation(?cwe, ?m)
Head:
  explainsMitigation(?vp, ?m)
```

#### E2 — SI9\_E2\_ExplainDefense

*Purpose:* Annotate Mitigations with D3FEND defense explanation. Produces 2,015 assertions.

```
Body:
  Mitigation(?m)
  ^ implementedBy(?m, ?d)
  ^ D3FENDTechnique(?d)
Head:
  explainsDefense(?m, ?d)
```

#### E3 — SI9\_E3\_ExplainComplianceGap

*Purpose:* Annotate VPs with a framework-outcome-association explanation predicate mirroring R1 output. Produces 5,318 assertions.

```
Body:
  VulnerabilityProfile(?vp)
  ^ affectsSubcategory(?vp, ?sc)
  ^ NISTSubcategory(?sc)
  ^ belongsToFunction(?sc, ?f)
Head:
  explainsComplianceGap(?vp, ?sc)
```

#### E4 — SI9\_E4\_ExplainRisk

*Purpose:* Annotate VPs with CWE-grounded risk explanation. Produces 147 assertions.

```
Body:
  VulnerabilityProfile(?vp)
  ^ mappedToCWE(?vp, ?cwe)
  ^ CWE(?cwe)
Head:
  explainsRisk(?vp, ?cwe)
```

### Sublayer SI-11 — Structured XAI Output Rules (X1–X5)

SI-11 rules formally specify the per-VP (X1, X2, X4, X5) or per-Mitigation (X3) creation of typed XAI justification individuals and their connection to the corresponding VP/Mitigation via `hasJustification`. Unlike R1–R4/E1–E4, these are individual-creation rules rather than pure join inference: one typed individual is created per VP (or Mitigation) and its content atoms are populated from whichever of the VP’s existing cross-framework links are present.

### X1 — SI11\_X1\_RiskJustification

*Purpose:* Create and link a RiskJustification individual per VP, annotated from the VP's CWE links. Produces 121 assertions.

```
Body:
  VulnerabilityProfile(?vp)
Head:
  RiskJustification(?rj)
  ^ hasJustification(?vp, ?rj)
  ^ derivedFromRule(?rj, "SI11_X1")
  ^ hasRiskLevel(?rj, ?lvl)
  ^ [foreach mappedToCWE(?vp, ?cwe):
    derivedFromCWE(?rj, ?cwe)]
```

### X2 — SI11\_X2\_MitigationJustification

*Purpose:* Create and link a MitigationJustification individual per VP, annotated from the VP's mitigation and CWE links. Produces 121 assertions.

```
Body:
  VulnerabilityProfile(?vp)
Head:
  MitigationJustification(?mj)
  ^ hasJustification(?vp, ?mj)
  ^ derivedFromRule(?mj, "SI11_X2")
  ^ hasRiskLevel(?mj, ?lvl)
  ^ [foreach explainsMitigation(?vp, ?m):
    derivedFromMitigation(?mj, ?m)]
```

### X3 — SI11\_X3\_DefenseJustification

*Purpose:* Create a DefenseJustification individual per Mitigation. Produces 42 assertions (mitigation-scoped, not per-VP).

```
Body:
  Mitigation(?m)
Head:
  DefenseJustification(?dj)
  ^ derivedFromMitigation(?dj, ?m)
  ^ derivedFromRule(?dj, "SI11_X3")
  ^ hasRiskLevel(?dj, ?lvl)
  ^ [foreach implementedBy(?m, ?d):
    derivedFromTechnique(?dj, ?d)]
  ^ [foreach supports(?d, ?n):
    derivedFromSubcategory(?dj, ?n)]
```

*Note:* no hasJustification triple links the source Mitigation to its DefenseJustification in the materialized output — unlike X1/X2/X4/X5, whose hasJustification(VP, ...) assertions are directly verified present. A DefenseJustification is reachable only via the reverse derivedFromMitigation link (query by object, not by traversing forward from the Mitigation).

### X4 — SI11\_X4\_ComplianceJustification

*Purpose:* Create and link a ComplianceJustification individual per VP, annotated from the VP's NIST CSF subcategory links. Produces 121 assertions.

```
Body:
  VulnerabilityProfile(?vp)
Head:
  ComplianceJustification(?cj)
  ^ hasJustification(?vp, ?cj)
  ^ derivedFromRule(?cj, "SI11_X4")
  ^ hasRiskLevel(?cj, ?lvl)
  ^ [foreach affectsSubcategory(?vp, ?sc):
    derivedFromSubcategory(?cj, ?sc)]
```

### X5 — SI11\_X5\_RecommendationStatement

*Purpose:* Create and link a RecommendationStatement individual per VP, annotated from the VP's NIST CSF function links. Produces 121 assertions.

```
Body:
  VulnerabilityProfile(?vp)
Head:
  RecommendationStatement(?rs)
  ^ hasJustification(?vp, ?rs)
  ^ derivedFromRule(?rs, "SI11_X5")
  ^ [foreach affectsFunction(?vp, ?f):
    derivedFromFunction(?rs, ?f)]
```

Rule bodies are reproduced from `rdfs:label` descriptions and blank-node atom chains in ontology owl file. Full OWL/XML serializations are available in the public repository [5]. Variables: `?vp=VulnerabilityProfile`, `?t=AttackTechnique`, `?m=Mitigation`, `?sc=NISTSubcategory`, `?f=Function`, `?d=D3FENDTechnique`, `?cwe=CWE`. The `[foreach ...]` notation in X1–X5 denotes one head atom per existing matching link and is not standard SWRL syntax; it is used because individual creation (a new `?rj`, `?mj`, etc.) is outside native SWRL semantics without a builtin, consistent with these rules being implemented procedurally (§IV-E) rather than executed by a SWRL engine.

## REFERENCES

- [1] National Institute of Standards and Technology, “The NIST Cybersecurity Framework (CSF) 2.0,” NIST CSWP 29, Feb. 2024. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- [2] A. Kougiumtzidou et al., “An end-to-end framework for cybersecurity taxonomy and ontology generation and updating,” in 2024 IEEE International Conference on Cyber Security and Resilience (CSR), IEEE, Sep. 2024, pp. 247–254. Accessed: Aug. 13, 2025. [Online]. Available: <https://doi.org/10.1109/csr61664.2024.10679346>
- [3] K. Madhavan, A. Yazdinejad, F. Zarrinkalam and A. Dehghantanha, “Quantifying Security Vulnerabilities: A Metric-Driven Security Analysis of Gaps in Current AI Standards,” arXiv preprint arXiv:2502.08610 [cs.CR], Feb. 2025. [Online]. Available: <https://arxiv.org/abs/2502.08610>
- [4] R. Agarwal, T. Elsaleh and E. Tragos, “GDPR-inspired IoT Ontology enabling Semantic Interoperability, Federation of Deployments and Privacy-Preserving Applications,” in 2022 IEEE 8th World Forum on Internet of Things (WF-IoT), IEEE, Oct. 2022, pp. 1–8. Accessed: Aug. 13, 2025. [Online]. Available: <https://doi.org/10.1109/wf-iot54382.2022.10152206>
- [5] M. A. Adelere, “RiskOnto: An Ontology-Driven Framework for Threat Modeling, Risk Reasoning, and Cyber Defense Knowledge Integration,” GitHub, Aug. 2025. [Online]. Available: <https://github.com/madelere/RiskOnto-v1/>
- [6] U.S. Department of Health and Human Services, “HC3 Intelligence Briefing: Cybersecurity Maturity Models,” Health Sector Cybersecurity Coordination Center (HC3), Aug. 2020. [Online]. Available: [https://www.hhs.gov/sites/default/files/cybersecurity\\_maturity\\_model.pdf](https://www.hhs.gov/sites/default/files/cybersecurity_maturity_model.pdf)
- [7] A. Al Hammouri and A. M. Al Bataineh, “A Unified Cybersecurity Ontology for Enhancing Cyber Threat Intelligence,” *Journal of Information Security and Applications*, vol. 58, p. 102710, 2020.
- [8] National Institute of Standards and Technology, “Security and Privacy Controls for Information Systems and Organizations,” NIST Special Publication 800-53, Rev. 5, Sep. 2020. doi: 10.6028/NIST.SP.800-53r5. [Online]. Available: <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
- [9] The MITRE Corporation, “MITRE D3FEND Knowledge Graph,” 2023. [Online]. Available: <https://d3fend.mitre.org/>
- [10] National Institute of Standards and Technology (NIST), “Guide for Conducting Risk Assessments,” NIST Special Publication 800-30 Revision 1, Sep. 2012. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>
- [11] J. Freund and J. Jones, “Measuring and Managing Information Risk: A FAIR Approach,” Butterworth-Heinemann, 2024.
- [12] European Union Agency for Network and Information Security (ENISA), “Interoperable EU Risk Management Framework,” European Union Agency for Cybersecurity. Accessed: Aug. 21,

2025. [Online]. Available: <https://www.enisa.europa.eu/publications/interoperable-eu-risk-management-framework>
- [13] D. Preuveneers and W. Joosen, "An Ontology-Based Cybersecurity Framework for AI-Enabled Systems and Applications," *Future Internet*, vol. 16, no. 3, p. 69, Feb. 2024, doi: 10.3390/fi16030069.
  - [14] M. Vålja, F. Heiding, U. Franke and R. Lagerström, "Automating threat modeling using an ontology framework," *Cybersecurity*, vol. 3, no. 1, Oct. 2020, doi: 10.1186/s42730-020-00060-8.
  - [15] K. S. Bughio, D. M. Cook and S. A. A. Shah, "Developing a Novel Ontology for Cybersecurity in Internet of Medical Things-Enabled Remote Patient Monitoring," *Sensors*, vol. 24, no. 9, p. 2804, Apr. 2024, doi: 10.3390/s27392804.
  - [16] U.S. Department of Energy, "Cybersecurity Capability Maturity Model (C2M2), Version 2.0," Office of Cybersecurity, Energy Security and Emergency Response, Jul. 2021. [Online]. Available: [https://www.energy.gov/sites/default/files/2021-07/C2M2\\_Version\\_2.0\\_July\\_2021\\_508.pdf](https://www.energy.gov/sites/default/files/2021-07/C2M2_Version_2.0_July_2021_508.pdf)
  - [17] J. S. Park and R. P. Lee, "Ontology based risk assessment for information security," *Computers & Security*, vol. 26, no. 7–8, pp. 594–601, 2007.
  - [18] Streamlit Inc., "Streamlit: The Fastest Way to Build and Share Data Apps," 2024. [Online]. Available: <https://streamlit.io/>
  - [19] A. Kougioumtzidou and M. Marengwa, "Ontology Driven Cybersecurity Learning Factory: A Use Case for Securing Electricity Utilities," in *Proceedings of the 13th International Conference on Formal Ontology in Information Systems (FOIS 2024)*.
  - [20] NIST, "The Design and Application of a Unified Ontology for Cyber Security," NIST Computer Security Resource Center, 2023.
  - [21] M. Poveda-Villalón, A. Gómez-Pérez and M.C. Suárez-Figueroa, "OOPS! (Ontology Pitfall Scanner!): An on-line tool for ontology evaluation," *International Journal on Semantic Web and Information Systems (IJSWIS)*, vol.10, no. 2, pp.7–34, 2014. Available: <https://oops.linkedata.es/>
  - [22] International Organization for Standardization, "ISO 31000:2018 Risk management — Guidelines," ISO, Geneva, Switzerland, 2018. [Online]. Available: <https://www.iso.org/standard/65694.html>
  - [23] OWASP, "WebGoat — A Deliberately Insecure Application" (development snapshot 2025.4-SNAPSHOT, following release v2025.3), OWASP Foundation, 2025. [Online]. Available: <https://github.com/WebGoat/WebGoat>
  - [24] P. Kaloroumakis and M. J. Smith, "OnToRisk: A Formal Ontology Approach to Automate Cyber Security Risk Identification," in *Proc. 16th Int. Conf. on Availability, Reliability and Security (ARES '21)*, Vienna, Austria, Aug. 2021, Article 48, pp. 1–6. doi: 10.1145/3465481.3470024.
  - [25] D. Golpayegani, H. J. Pandit and D. Lewis, "AIRO: An Ontology for Representing AI Risks Based on the Proposed EU AI Act and ISO 31000," ADAPT Centre, Trinity College Dublin, 2022. Available: <https://w3id.org/airo>
  - [26] M.C. Suárez-Figueroa, A. Gómez-Pérez and M. Fernández-López, "The NeOn Methodology for Ontology Engineering," in *Ontology Engineering in a Networked World*, M.C. Suárez-Figueroa, A. Gómez-Pérez, E. Motta and A. Gangemi, Eds. Berlin: Springer, 2012, pp. 9–34. doi: 10.1007/978-3-642-24794-1\_2.
  - [27] Institute of Computer Science, University of Rostock, "OntoMetrics: Ontology Metrics Calculation Service," [Online]. Available: <http://ontometrics.informatik.uni-rostock.de/>
  - [28] M. A. Musen, "The Protégé project: A look back and a look forward," *AI Matters*, vol. 1, no. 4, pp. 4–12, Jun. 2015, doi: 10.1145/2757001.2757003.
  - [29] Z. Syed, A. Padia, T. Finin, L. Mathews and A. Joshi, "UCO: A Unified Cybersecurity Ontology," in *Proc. AAAI Workshop on Artificial Intelligence for Cyber Security (AICS)*, Austin, TX, Feb. 2016.
  - [30] E. Kiesling, A. Ekelhart, K. Kurniawan and A. Quirchmayr, "SEPSSES: Building an Integrated Knowledge Graph for Cybersecurity," in *Proc. Int. Semantic Web Conf. (ISWC)*, Lecture Notes in Computer Science, vol. 11779, Springer, 2019, pp. 385–400. doi: 10.1007/978-3-030-30796-7\_24.